

CRAFT Certificate Workflows and Tickets

Certificate Request Agent for Tickets | Process Overview

CRAFT lets a user obtain Kerberos credentials noninteractively from a trusted Linux endpoint, including a host that is not domain-joined. It first checks for a user-supplied certificate and key in the actual home directory and can run this workflow entirely unprivileged. If the pair is absent, an authorized enrollment deployment obtains a short-lived certificate on the user's behalf. Both paths save a ticket-granting ticket (TGT) for unattended applications without retaining the user's AD password.

Unprivileged Home Certificate Workflow

Install craft and craft-worker as ordinary mode-0755 executables and provide readable, root-controlled /etc/craft policy, trust anchors and CRLs. No service account, enrollment keytab, LDAP, agent, CES or /run/craft is required. Place an existing unencrypted PEM pair at the fixed NSS-home paths:

```
mkdir -p ~/.config/craft
chmod 0700 ~/.config/craft
install -m 0600 /path/to/certificate.pem ~/.config/craft/user.pem
install -m 0600 /path/to/private-key.pem ~/.config/craft/user.key
```

Both files must be caller-owned regular files with one hard link, without symlinks, nonempty and at most 1 MiB each. The key must be private; the home and certificate directories must not be group/world-writable. CRAFT ignores HOME and XDG overrides when locating the pair.

A complete pair takes priority, including on an enrollment-enabled host. Partial, unsafe, encrypted or invalid inputs fail and retain the cache. Enrollment is selected only when both files are absent; it requires the setuid installation. A home-only installation reports the enrollment requirement if no pair exists.

Certificate Selection and Authentication

Administrators configure public Kerberos policy, trusted certificate authorities and current revocation lists. Configuration ships disabled. Enrollment additionally requires directory access, CES, an agent and CA recipient restrictions. The user invokes craft with no arguments; the selected certificate workflow proceeds as follows.

Stage	What Happens
1 Identify the caller	CRAFT checks the real UID, NSS username and home. Root invocation is refused. Enrollment-enabled execution is controlled by craft-users; an ordinary home-only installation needs no special group.
2 Select the source	Open the home pair as the caller. A complete pair takes priority. An absent pair selects enrollment; partial or unsafe files fail without fallback.
3 Prepare the certificate	Home mode loads the supplied PEM pair as the caller. Enrollment uses the craft account to resolve the AD UPN, generate a key/CSR and submit an agent-signed request through CES.
4 Validate the certificate	Both paths check key, logon usage, validity, CA trust and CRLs. Enrollment additionally pins directory UPN, template, three EKUs and short validity; home mode accepts ordinary templates and lifetimes.
5 Obtain a ticket	PKINIT requests the fixed Linux-name principal. The KDC maps the certificate and decides the grant; CRAFT checks returned identity, flags, encryption and lifetimes.
6 Publish the cache	After validation, the caller atomically replaces .krb5cc_craft, mode 0600, and prints its FILE cache name. Failures retain the existing cache.

Use the Cache to Access AD Resources

After authentication, the user selects the resulting credential cache for an application, typically through KRB5CCNAME. The Kerberos library uses the cached ticket-granting ticket (TGT) to request service tickets from the domain controller for the target services. Those tickets let the application authenticate as the user to resources such as SMB file shares, LDAP directories, and Kerberos-enabled web services, where supported and configured. Access remains subject to the user's permissions and the service's policy; obtaining a ticket does not grant additional access rights.

Identity and Trust

Both workflows request <Linux username>@<configured realm> and check the returned TGT principal. The KDC enforces certificate-to-account mapping. Enrollment checks the issued UPN against the directory lookup and pins the configured template; a requested CN cannot change that identity. Home mode makes no LDAP lookup and relies on KDC mapping. Enrollment-agent and recipient restrictions govern new issuance, while a supplied certificate remains subject to its issuer's policy and KDC acceptance. [1, 2]

CRAFT supports automation alongside MFA-protected interactive sign-in, but does not perform an MFA challenge or prove one was completed. Home mode depends on the supplied certificate/private key and KDC mapping. Enrollment also depends on the managed host, agent credentials and CA restrictions.

Certificate Storage and Cleanup

Certificate Files in Each Workflow

Home mode reads ~/.config/craft/user.pem and user.key as the caller. Those source files persist until the user replaces or removes them; CRAFT does not renew, overwrite or delete them. It releases its parsed identity and sealed memory-file copies when authentication ends. Protect the supplied private key as a reusable credential and replace the pair before certificate expiry.

Enrollment generates a fresh user private key. Its issued certificate and key remain in process memory and temporary memory files for PKINIT and are released on success or failure. CRAFT does not export a user PEM/PFX or install a certificate-store entry. The generated private key is not submitted to the CA.

What Remains on the Linux Host

Both workflows publish .krb5cc_craft in the caller's actual home. This persistent cache contains the TGT and session key, without the user certificate/private key. It is caller-owned with mode 0600 and remains until replaced or removed; expiry does not delete it automatically. Home mode also leaves the supplied PEM files in place.

Public configuration, trust anchors and CRLs under /etc/craft remain root-controlled and readable by callers. Enrollment additionally retains private agent/keytab/transport credentials and uses /run/craft for per-user issuance locks and timestamps. A home-only installation needs neither the service account nor those private files and runtime directory.

What the Certificate Authority Retains

Client cleanup does not erase the CA's copy of an issued certificate or its enrollment and audit records. A failed or interrupted run can still leave an issued certificate recorded at the CA. CRAFT does not automatically revoke that certificate or cancel the request. Administrators manage CA retention, audit review, and any required revocation.

What Ephemeral Means Here

Enrollment's user certificate and key are ephemeral on the client; supplied home files are persistent. In either mode, memory and memory files can reach swap or privileged host capture. Protect the host, its private key files and ticket cache. Certificate expiry, key deletion or process exit does not revoke an already-issued Kerberos ticket.

Ticket Lifetimes and Everyday Use

Certificate and Ticket Lifetimes

Enrollment's default certificate acceptance cap is 36,000 seconds (10 hours) of total validity including backdating. Home mode accepts ordinary certificate validity and other templates. Both require current validity, matching keys, supported logon usage, trusted chains and current CRLs. A supplied certificate does not have to use CRAFT's enrollment template.

CRAFT requests a 10-hour initial TGT and a 7-day renewal window. A renewal window is the period during which an eligible ticket can be renewed, not seven days of uninterrupted ticket validity. The domain controller controls the actual grant, and PKINIT can constrain the initial ticket by the certificate/key lifetime. [3, 4]

By default, `require_full_tgt_lifetime=yes` rejects a shortened initial grant or renewal window without replacing the existing cache. An administrator may set `require_full_tgt_lifetime=no` to accept shorter grants with a warning. CRAFT never rewrites the domain controller's ticket times.

Select the Cache and Use Applications

Run CRAFT as the intended user, without `sudo`. Select its returned cache in the current shell, then inspect the ticket:

```
cache=$(/usr/local/bin/craft) && export KRB5CCNAME="$cache" && \
  klist -ef -c "$KRB5CCNAME"
```

Kerberos-aware applications launched from that shell can use the cache. CRAFT cannot change its parent shell's environment. The optional `with-craft` wrapper can run a command with a newly obtained cache already selected.

Renewal and Failed Attempts

Renew manually with `kinit -R -c "$KRB5CCNAME"` or use `craft-maintain`. Renewal needs only the cache. Fresh authentication reuses a valid home pair; when both files are absent, enrollment supplies a new certificate.

Partial, unsafe or invalid home inputs fail without enrollment fallback or cache replacement. Only success replaces the cache. Enrollment attempts have a per-user interval; home mode does not. Review AUTHPRIV/KDC logs and CA/CES logs for enrollment, and follow the lab acceptance checks.

Long Running Jobs

Start once as the approved batch user; it returns when credentials and detached maintenance are ready. No job wrapper or cron is needed.

```
job_pid=$$
cache=$(/usr/local/bin/craft-maintain --watch-pid "$job_pid") || exit "$?"
export KRB5CCNAME="$cache"
```

`craft-maintain` renews TGTs from the cache and obtains fresh credentials near the absolute renewal deadline. Ten-hour/seven-day grants normally renew at eight hours and authenticate afresh around day six. Fresh acquisition uses the same home-pair priority; it does not renew a supplied certificate. Actual grants set the schedule.

Use `--max-duration 21d` to add a cutoff. Maintenance stops with the watched PID; keep the shell alive, exec the job, or watch its controller. Jobs for one user share cache updates; stopping maintenance leaves the cache intact.

```
/usr/local/bin/craft-maintain --status --watch-pid "$job_pid"
klist -ef -c "$KRB5CCNAME"
```

Refresh failures preserve the cache and retry. Failed fresh acquisitions share a one-minute to one-hour cooldown in either mode. Check status and AUTHPRIV logs; later failures leave the job running. Keep the supplied pair and CRLs current, and have applications reload refreshed credentials.

Install `craft-maintain` without `setuid/setgid`. Renewal requires Linux 5.3+, `/proc` and system `/etc/krb5.conf` matching the configured realm/KDC. Home-only refresh works under `no_new_privs`. Enrollment fallback additionally requires later `setuid craft` calls. The scheduler must retain background processes; see `source/README.md` for setup and status.

Primary References

- [1] [Microsoft MS-WCCE: enrollment-on-behalf-of CMS requests](#)
- [2] [Microsoft MS-WCCE: CA certificate SID security extension](#)
- [3] [RFC 4556, sections 3.2.2–3.2.3: client certificate usage and ticket/key lifetime](#)
- [4] [Microsoft: Maximum lifetime for user ticket \(hours\)](#)

License

CRAFT source code, scripts, configuration examples, and documentation are licensed under the GNU General Public License, version 3 (SPDX: GPL-3.0-only). See the repository LICENSE file or <https://www.gnu.org/licenses/gpl-3.0.html> for the full terms. This material is provided without warranty, as described in the license.